

Sicurezza (cenni)

Antonio Pecchia

antonio.pecchia@unisannio.it

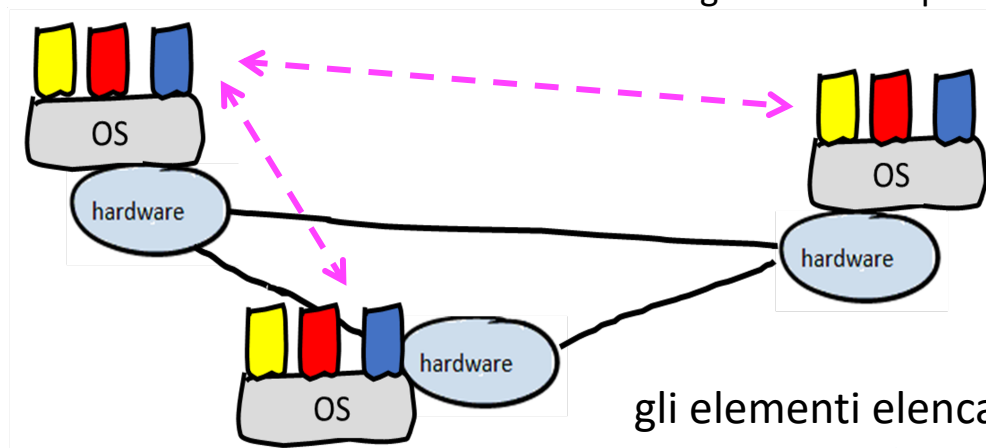
Dipartimento di Ingegneria
Laurea in Ingegneria Informatica
Sistemi Operativi



UNIVERSITÀ DEGLI STUDI
DEL SANNIO Benevento

I sistemi moderni

dispositivi hardware ...
gestiti da SO ...
che eseguono applicazioni...
collegati da reti...
interazioni governate da protocolli...



gli elementi elencati possono
contenere **vulnerabilità**

Un po' di terminologia

- ❑ **Bug**: *difetto*, per es. un errore nella scrittura di un SW;
- ❑ **Vulnerabilità**: un bug nella **sicurezza**;
- ❑ **Exploit**: input che attiva la vulnerabilità;
- ❑ **Malware**: software "nocivo":
 - software che *infetta* un computer iniettandosi come **virus** in altri file (spesso eseguibili) o tramite *interazione* con l'utente;
 - **worm**: malware che si propaga autonomamente;
 - *cavallo di Troia* (**trojan**) malware *nascosto* in un SW lecito.

Buffer overflow

```
01. void A( ) {  
02.     char B[128];      /* riserva un buffer con spazio per 128 caratteri sullo stack */  
03.     printf ("Inserire messaggio di log:");  
04.     gets (B);         /* legge il messaggio di log dallo standard input nel buffer */  
05.     writelog (B);     /* scrive la stringa ben formattata nel file di log */  
06. }
```

La ricerca di "**buffer overflow**" su CVE (Common vulnerabilities and exposures) restituisce 16350 record (Dicembre 2024). <https://cve.mitre.org>

HOME > CVE > SEARCH RESULTS

Search Results

There are **16350** CVE Records that match your search.

Name	Description
CVE-2024-9915	A vulnerability classified as critical was found in D-Link DIR-619L B1 2.06. Affected by this vulnerability is the function formVirtualServ of the file /goform/formVirtualServ. The manipulation of the argument curTime leads to buffer overflow. The attack can be launched remotely. The exploit has been disclosed to the public and may be used.

* Cap. 9, par. 9.5.1 (fino a 'stack canaries' escluso)

Buffer overflow

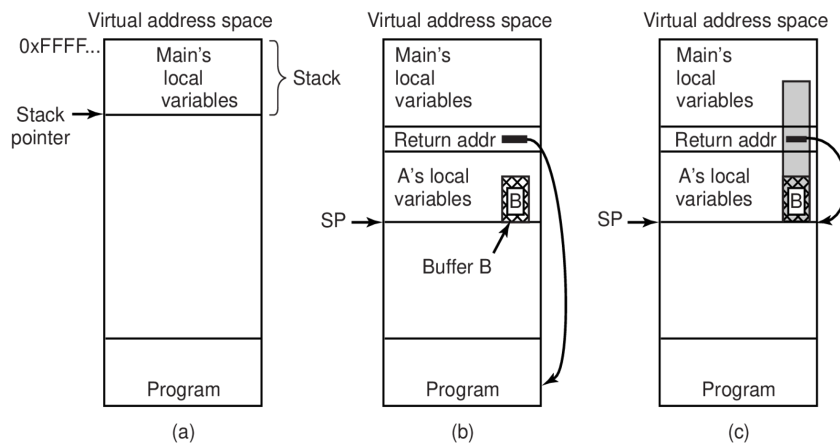


Figure 9-17. (a) Situation when the main program is running. (b) After the procedure A has been called. (c) Buffer overflow shown in gray

* Cap. 9, par. 9.5.1 (fino a 'stack canaries' escluso)

Attacchi e malfunzionamenti sono inevitabili

FINANCIAL TIMES

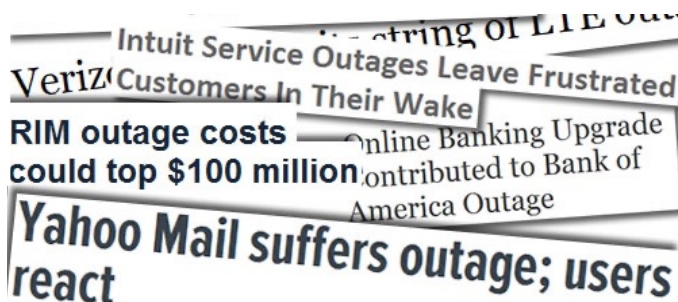
June 25, 2012 6:45 pm

The upgrade that downed Royal Bank of Scotland

By Brooke Masters, Elaine Moore and Jim Pickard



As Royal Bank of Scotland struggled for a sixth day to cope with the aftermath of a software glitch that hit its payments processing system, risk experts



Cyber caos nel mondo, disagi negli aeroporti: ritardi, voli e prenotazioni cancellati

Il bug informatico ha messo in crisi le autorità aeroportuali. Negli Usa, in Europa, e in Medio Oriente i disagi hanno coinvolto milioni di persone. Per ore sono rimaste bloccate numerosi servizi aeroportuali, check-in e prenotazioni

20/07/2024

[Home](#) / [Comunicazione](#)

/ Cyberattacchi in crescita nel settore sanitario, dati digitali nel mirino degli hacker

Cyberattacchi in crescita nel settore sanitario, dati digitali nel mirino degli hacker



Non solo Internet

- I computer sono alla base di tantissime attività umane.



Financial Services



Surveillance of large events and expos



Transportation



Power Grids



Smart Cities

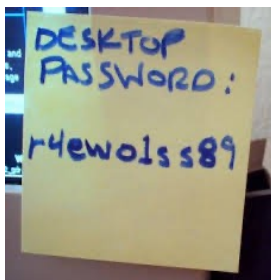
Stuxnet, 2010 – Compromise of Iranian nuclear plants



Maroochy Shire **Waste Water Attack, 2000** - 265,000 gallons of untreated sewage released into waterways

Il fattore umano

- ❑ Un **componente** del cyberspace a tutti gli effetti:
 - e forse la vulnerabilità più grande ...
- ❑ Pratiche sbagliate, scarsa consapevolezza del rischio;
- ❑ Insiders, fake news, phishing, social engineering, ...



SECURITY CHECK 

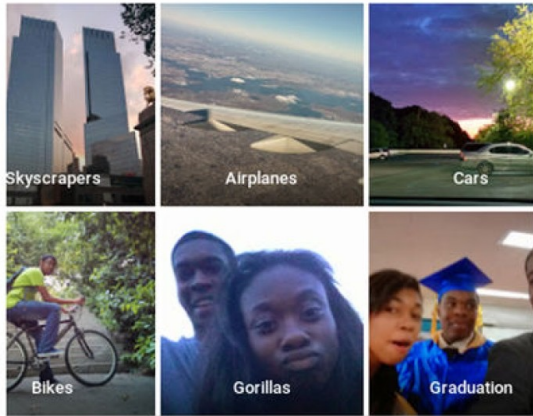
Is there your card in the hackers database?
You can easily check here, just enter your card info:

Card number:

CVC@ (CW2):

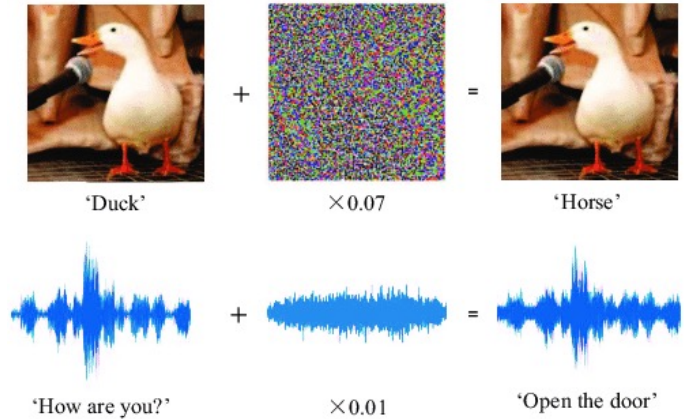
Il fattore AI (artificial intelligence)

Google Photos, y'all [REDACTED] up. My friend's not a gorilla.



Sorgente

[Google Mistakenly Tags Black People as 'Gorillas,' Showing Limits of Algorithms - WSJ](#)



Cybersecurity

Cybersecurity: The **protection of information** against unauthorized disclosure, transfer, modification, or destruction, whether **accidental** or **intentional**.

adapted from “*Cyberterrorism Preparedness Act of 2002*”

Cybersecurity

Cybersecurity: **information assurance**, including scientific, technical, management, or any other relevant disciplines required to ensure computer and network security, **including, but not limited to**, a discipline related to the following functions:

- (A) Secure System and network administration and operations.
- (B) Systems security engineering.
- (C) Information assurance systems and product acquisition.
- (D) Cryptography.
- (E) Threat and vulnerability assessment, including risk management.
- (F) Web security.
- (G) Operations of computer emergency response teams.
- (H) Cybersecurity training, education, and management.
- (I) Computer forensics.
- (J) Defensive information operations.

adapted from “*Cybersecurity Research and Education Act of 2002*”

Lo scenario

Tabella 1.1: Attacchi subiti da imprese italiane, settembre 2015–2016

Area geografica	
Nord Ovest	44,2
Nord Est	47,3
Centro	52,3
Sud e Isole	35,9
Numero di addetti	
20 – 49	42,7
50 – 199	48,4
200 – 499	56,0
500 e oltre	62,8
Intensità tecnologica	
Alta e medio-alta	48,8
Bassa e medio-bassa	43,8
Incidenza delle esportazioni sul fatturato	
Meno di 1/3	43,0
Tra 1/3 e 2/3	51,8
Più di 2/3	48,5
Percentuale sul totale delle aziende	
	45,2

Spesa in sicurezza
informatica **dell'impresa**
mediana nel 2016:

4530 EUR

*“50% of EU businesses have suffered
a cyber-attack”* (fonte European
Cyber Security Organization - ECSO)

Sorgente: Libro Bianco: “Il Futuro della Cybersecurity in Italia: Ambiti Progettuali Strategici”

ALCUNI ARGOMENTI CONCLUSIVI

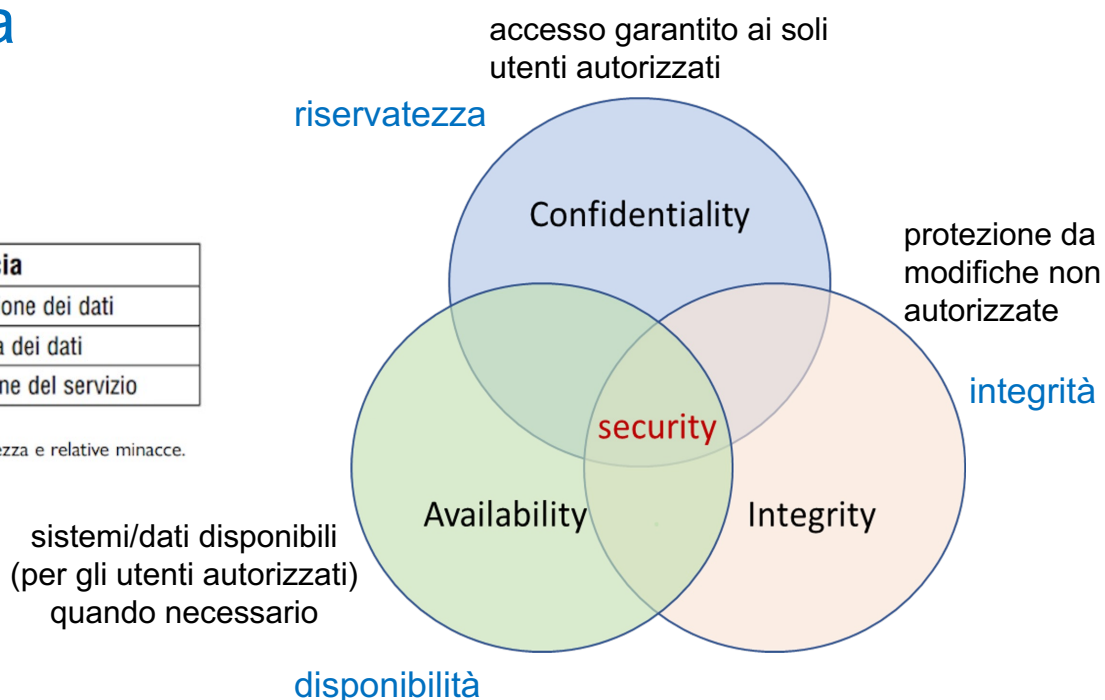
Cap 9 Introduzione e par. 9.1 (fino a 9.1.1, incluso);
par 9.2 (escluso 9.2.3);

Cap 5 par 5.4.3 (esclusi RAID di livello 2 e 3).

Sicurezza

Obiettivo	Minaccia
Riservatezza	Esposizione dei dati
Integrità	Modifica dei dati
Disponibilità	Negazione del servizio

Figura 9.1 Obiettivi della sicurezza e relative minacce.

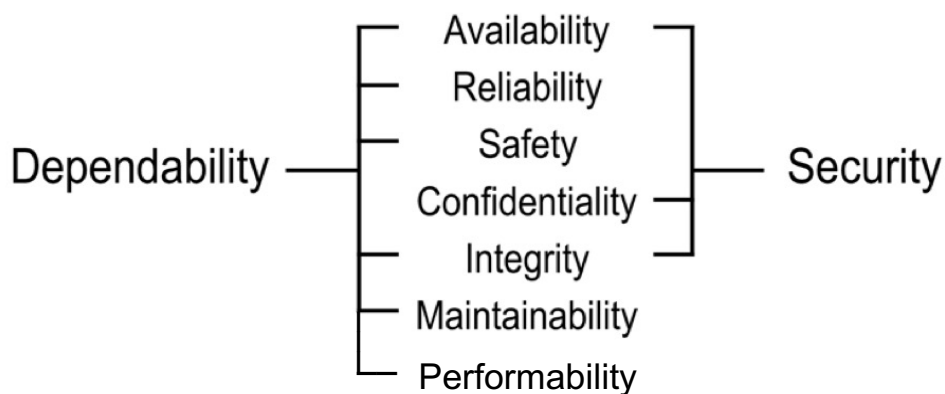


Cybersecurity

Cybersecurity = ^{sicurezza} *availability*, *integrity* and *confidentiality* of ^{cyberspace} information systems and networks in face of **attacks**, **accidents** and **failures** with the *goal of protecting operations and assets**.

* Operations and assets that depend on information systems and networks

Dependability



Sicurezza in Linux

- ❑ Gli **utenti** di un sistema Linux hanno uno **UID** (ID utente):
 - superuser (o **root**): UID=0 – può leggere/scrivere tutti i file;
- ❑ Gli utenti sono organizzati in gruppi che hanno un *id* detto **GID** (ID di gruppo);
- ❑ Ogni **processo** ha UID-GID del proprietario;
- ❑ Un **file** *eredita* UID-GID del processo che lo crea ed un set di permessi determinati dal processo che lo crea.

111000000	rwX-----	Il proprietario può leggere, scrivere ed eseguire
110100100	rw-r--r--	Il proprietario può leggere e scrivere; tutti gli altri possono leggere

Controllo dell'accesso alle risorse

- ❑ **Dominio di protezione:** insieme di **coppie** (*oggetto, diritti*):
 - **oggetto:** **HW** (segmenti di memoria, disco, ...) o **SW** (file, database, semafori, ...);
 - **diritto:** permesso di eseguire una operazione (leggi, scrivi, esegui, up, down, ...).

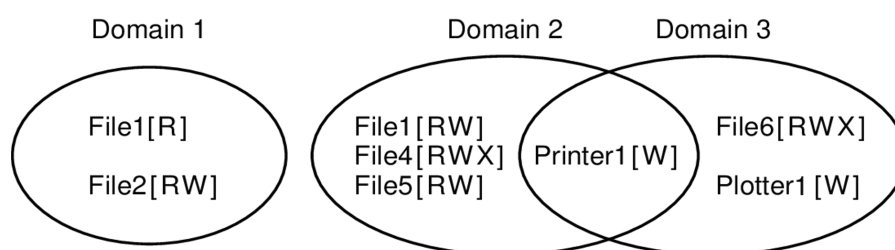


Figure 9-3. Three protection domains

Controllo dell'accesso alle risorse

- **Dominio di protezione:** insieme di **coppie** (*oggetto, diritti*):
 - in ogni momento, ciascun **processo** (o, più in generale, **dominio di sicurezza**, per es., una VM, il kernel, o i processi) è eseguito in qualche dominio di protezione;

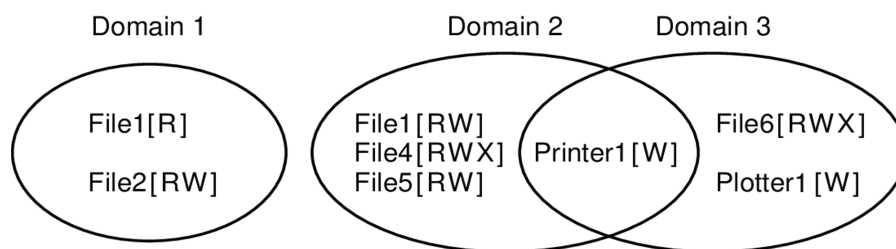


Figure 9-3. Three protection domains

Processo e dominio di protezione

- In UNIX (e quindi LINUX) il dominio di protezione di un **processo** è definito dai suoi UID-GID:
 - quando un **utente** esegue l'accesso al sistema, la shell recupera UID-GID dell'utente e, questi, sono ereditati da tutti i figli;
 - processi con gli stessi UID-GID hanno accesso al medesimo insieme di oggetti.

```
$ id studente
uid=1000(studente) gid=1000(studente) gruppi=1000(studente),4(adm),24(cdrom),
27(sudo), 30(dip),46(plugdev),120(lpadmin),133(lxd),134(sambashare),135(docker)
```

```
$ groups studente
studente : studente adm cdrom sudo dip plugdev lpadmin lxd sambashare docker
```

Matrice di protezione

Domain	Object							
	File1	File2	File3	File4	File5	File6	Printer1	Plotter2
1	Read	Read Write						
2			Read	Read Write Execute	Read Write		Write	
3						Read Write Execute	Write	Write

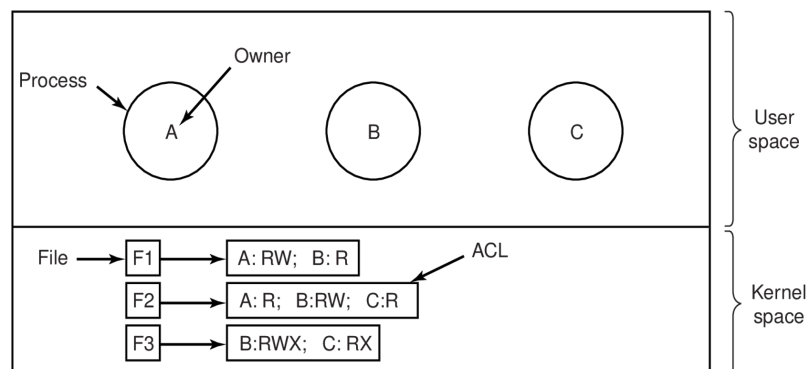
Figure 9-4. A protection matrix

Domain	Object										
	File1	File2	File3	File4	File5	File6	Printer1	Plotter2	Domain1	Domain2	Domain3
1	Read	Read Write								Enter	
2			Read	Read Write Execute	Read Write		Write				
3						Read Write Execute	Write	Write			

Figure 9-5. A protection matrix with domains as objects.

Access Control List (ACL)

- Per ogni oggetto, è associata una **lista ordinata** contenente i domini che vi possono accedere e in che modo:
 - ai fini dell'esempio in figura, ciascun dominio corrisponde ad un *utente*.



ACL con gruppi di utenti

- Formato di una ACL con **gruppi di utenti**:

ACL: UID1, GID1: rights1; UID2, GID2: rights2; ... UID = user ID
GID = group ID

File	Lista di controllo degli accessi
Password	tana, sysadm: RW
Pigeon_data	bill, pigfan: RW; tana, pigfan: RW; ...

tana, bill sono **utenti**

sysadm, pigfan sono **gruppi**

```
tana, *:RW                                //    dai accesso RW all'utente tana indipendentemente dal
                                           gruppo con cui ha effettuato il login

anna, *: (none); *, *: RW                //    dai accesso RW a tutti, eccetto anna (NOTA: la lista
                                           è analizzata in ordine.
```

ACL in Linux

- Visualizzazione-modifica ACL: **getfacl** o **setfacl**.

```
$ getfacl mutex.c
# file: mutex.c
# owner: studente
# group: studente
user::rw-
group::r--
other::r--
```

- chmod**: il comando *chmod* modifica i bit di modalità di accesso e gli elenchi di controllo accessi.

RAID

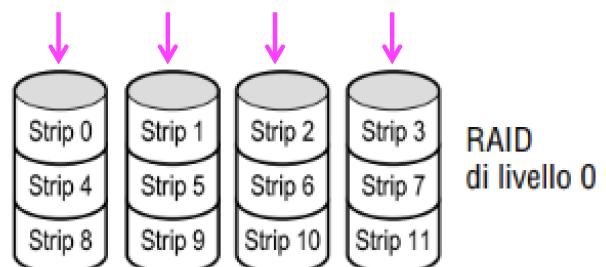
- ❑ **Redundant Array of Inexpensive Disks (RAID):**
 - tecnica per migliorare **prestazioni** ed **affidabilità** dei sistemi di memorizzazione su dischi (applicabile anche ad SSD);
 - **idea base:** utilizzare **più dischi** al posto di un solo disco*;
 - Il RAID è "visto" dal SO come un singolo disco; *internamente*, il RAID distribuisce i dati su più dischi.

* Talvolta denominato *Single Large Expensive Disk (SLED)* .

RAID di livello 0

- ❑ Concetto di **strip** (striscia): k settori:
 - strip 0: settori $0; (k-1)$;
 - strip 1: settori $k; (2k-1)$;
- ❑ **Esempio:** per leggere 4 strip consecutive, il **controller RAID** genera 4 comandi in parallelo (uno per disco).

strip *consecutive* sono disposte
in modalità round-robin

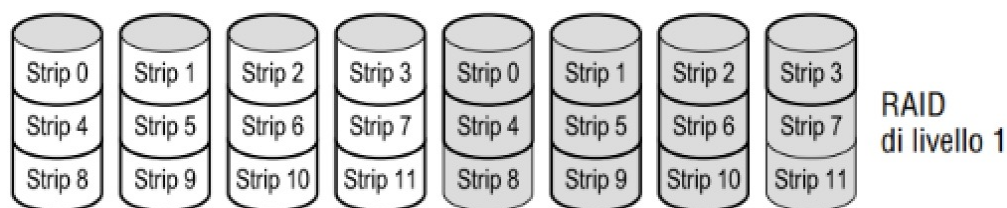


PRO: prestazioni;

CONTRO: affidabilità (!);

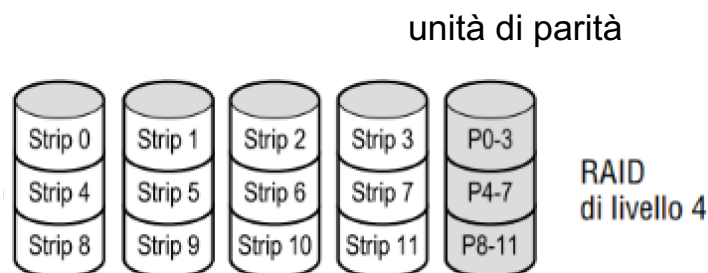
RAID di livello 1

- Duplicazione di tutti i dischi:
 - in **scrittura**, ogni strip è scritta due volte;
 - in **lettura**, si può usare una qualsiasi copia.



RAID di livello 4

- Simile a RAID 0, ma con parità *strip-per-strip* (OR esclusivo di tutte le strip) scritta su una unità extra;
- **Pro**: possibile ricalcolare le strip di una unità persa;
- Contro**: l'unità di parità diventa un collo di bottiglia.



RAID di livello 5 e 6

- Nel **RAID di livello 5**, i bit di parità sono distribuiti tra tutte le unità in stile *round-robin*.
- **RAID 6**: simile a RAID di livello 5, con blocco di parità **aggiuntivo**.

